Agent-Passport: Cryptographic Hop-Attenuated Macaroon Delegation, Autonomous System Path-Vector Loop Prevention, and Wire-Enforced Human-in-the-Loop Draft Locks for Multi-Agent A2A and MCP Swarms

Aniket Agrawal
Google Cloud, Customer Engineering & AI Architecture
Google Inc.
aniketagrawal@google.com

***Abstract*—As enterprise organizations transition from single-turn conversational assistants to hierarchical multi-agent swarms speaking the open Agent2Agent (A2A) protocol and the Model Context Protocol (MCP) across serverless infrastructures such as Google Cloud Run and Vertex AI Agent Engine, four coupled security, reliability, and regulatory bottlenecks emerge at the network transport boundary: (1) *Dual-Identity Header Collision and Cross-Hop Privilege Escalation*, where forwarding raw user OAuth 2.0 bearer tokens across intermediate sub-agents violates the Principle of Least Privilege and collides with serverless infrastructure IAM tokens in standard `Authorization` headers, while centralized OAuth 2.0 Token Exchange (IETF RFC 8693) introduces 10–15 ms of network round-trip latency per hop; (2) *In-Memory Credential Persistence*, where Python and Node.js agent runtimes retain plaintext bearer strings in garbage-collected heap memory across asynchronous turns; (3) *Cross-Agent Delegation Loops*, where cyclic A2A topologies induce unbounded token amplification and authentication deadlocks; and (4) *Unenforced Prompt-Level Human-in-the-Loop (HITL) Governance*, where enterprise mandates requiring "Draft-Only" staging for executive communications or human co-signatures for high-risk Human Resources (HR) decisions under EU AI Act Article 14 rely solely on probabilistic system prompt instructions.**

We introduce Agent-Passport, a zero-trust cryptographic wire protocol and transport gateway middleware for A2A and MCP swarms. Agent-Passport unifies four verifiable mechanisms directly on HTTP/2 and JSON-RPC 2.0 transport frames: (i) *Non-Interactive Chained HMAC-SHA256 Macaroon Attenuation* (paired with an asymmetric Ed25519 federation mode for untrusted cross-domain boundaries), Dual-Header Serverless Passthrough (`X-Serverless-Authorization` + `X-Agent-Passport-Macaroon`), and Gateway-Wrapped Encrypted Backend Credentials (`X-Encrypted-Backend-Credential`), enabling any intermediate agent to monotonically narrow OAuth scopes, execution modes, and conjunctive parameter predicates in $\mathcal{O}(1)$ local CPU time ($\approx$ 4.2 μs/hop holder attenuation; $+4.6$ μs/hop gateway verification) without contacting a central Identity Provider (IdP) or observing plaintext root OAuth tokens; (ii) *Sender-Constrained BGP-Inspired Autonomous System Path-Vector (`AS-PATH`) Loop Detection* via `X-A2A-Origin-Path-Vector`, deterministically terminating cyclic delegation graphs at the wire boundary via JSON-RPC error `-32097`; (iii) *Protocol-Level Stage-and-Hold Draft Locks*, intercepting mutating tool calls under `DRAFT_STAGED` or `COMMIT_WITH_HITL` caveats to return `HTTP 202 Accepted` with a signed `X-HITL-Draft-Lock-Token` or `HTTP 428 Precondition Required` until a human verifier provides a replay-protected Ed25519/HMAC co-signature over the RFC 8785 canonical payload digest in `X-HITL-Human-Cosignature`; and (iv) *Deferred In-Place Buffer Zeroization*, decrypting backend credentials only after MAC and policy verification into a pre-allocated `mlock`-pinned `bytearray` passed via `memoryview`, overwriting physical buffer bytes via `ctypes.memset` upon turn exit, and emitting a signed `X-Passport-Zeroization-Receipt`. Across $N = 1{,}200$ uniformly hop-stratified enterprise traces ($n_k = 300$ per hop for $k \in \{1, 2, 3, 4\}$), Agent-Passport Mode A achieves an overall mean verification latency of 0.2919 ± 0.019 ms ($p_{99} = 0.5240$ ms) and a 4-hop mean of 0.2988 ± 0.021 ms (0.5006 ± 0.034 ms overall and 0.6032 ± 0.039 ms at 4 hops in Ed25519 Mode B)—a $3.3\times$ speedup at 4 hops over a local in-memory RFC 8693 JWT/HMAC IdP (0.9896 ms) and a $139.5\times$ speedup over networked RFC 8693 token exchange (41.6780 ms)—while delivering 100.0% enforcement across all five security and governance invariants.

***Index Terms*—Agent2Agent (A2A) Protocol, Model Context Protocol (MCP), Macaroons, Zero-Trust Architecture, Least-Privilege Delegation, BGP AS-Path Loop Prevention, Human-in-the-Loop Governance, EU AI Act Article 14, Cryptographic Memory Zeroization.**

I. Introduction

Enterprise artificial intelligence is undergoing a structural architectural transition from monolithic, single-model chat interfaces to distributed, multi-agent ecosystems [1]–[4]. In modern production deployments on Google Cloud Gemini Enterprise, Vertex AI Agent Development Kit (ADK), and Cloud Run, a top-level orchestrator agent decomposes complex enterprise objectives and delegates specialized sub-tasks across domain-specific peer agents via the open **Agent2Agent (A2A)** protocol [2], which in turn invoke transactional tools exposed by enterprise systems of record (such as SAP S/4HANA, Workday, Microsoft 365 Graph, Jira, and BigQuery) via the **Model Context Protocol (MCP)** [3].

While A2A and MCP standardize capability advertisement (`.well-known/agent.json` and `tools/list`) and task invocation (`tasks/send` and `tools/call`), production deployments across regulated enterprise environments expose four severe architectural vulnerabilities at the intersection of cloud-native identity management, multi-hop delegation, and regulatory compliance:

1) **Dual-Identity Header Collision and Cross-Hop Confused Deputy Escalation:** When an enterprise employee authenticates into a primary orchestrator agent (e.g., via OAuth 2.0 / OpenID Connect [5], [6]) and that orchestrator invokes a downstream A2A sub-agent or FastMCP server hosted on serverless infrastructure (such as Google Cloud Run [7]), two orthogonal authentication contexts must traverse the same HTTP/2 transport connection: (a) the cloud platform's container-to-container infrastructure identity (a Google-signed OIDC ID token validating IAM permission `roles/run.invoker`), and (b) the end-user's attenuated enterprise authority. In practice, two failure modes arise: (i) standard A2A and MCP client SDKs default to placing infrastructure OIDC tokens in `Authorization: Bearer` [8], colliding directly with user OAuth tokens, and (ii) even when deployments pass the Cloud Run IAM token in `X-Serverless-Authorization` [7] and forward the user's OAuth token in `Authorization`, intermediate sub-agents either receive the user's raw root OAuth token in plaintext (enabling Confused Deputy privilege escalation [5] or direct SaaS API harvesting under indirect prompt injection [9]–[11]) or must execute k synchronous OAuth 2.0 Token Exchange round-trips (IETF RFC 8693 [12]–[14], adding $k \times 10$–15 ms of blocking network latency).
2) **Garbage-Collected Heap Credential Residency:** Even when user bearer tokens are passed via custom request headers or ADK `before_tool_callback` hooks, standard high-level runtimes (Python, Node.js, Java) deserialize plaintext bearer credentials into immutable string objects during HTTP header parsing. These objects persist in garbage-collected heap memory across asynchronous coroutines, long-running multi-tenant container instances, and crash core dumps long after a reasoning turn terminates [15], [16], violating strict enterprise zero-trust credential hygiene [17] and ISO/IEC 27001 cryptographic key lifecycle controls.
3) **Cyclic A2A Delegation Loops and Callback Deadlocks:** In dynamic multi-agent meshes where peer agents discover capabilities via `.well-known/agent.json` Agent Cards, cyclic routing dependencies frequently emerge (e.g., Orchestrator $A_1 \rightarrow$ Analytics Agent $A_2 \rightarrow$ Data Quality Agent $A_3 \rightarrow A_1$). Neither A2A nor MCP defines a transport-layer path-vector header analogous to Border Gateway Protocol (BGP-4) Autonomous System Path (`AS_PATH`) attributes [18]. Furthermore, when agents implement ad-hoc token refresh inside client-side `before_tool_callback` interceptors without wire-level hop provenance, mutual recursion triggers synchronous callback deadlocks, runaway token expenditure, and cascading container exhaustion.
4) **Probabilistic Prompt-Only Human-in-the-Loop (HITL) Governance:** Enterprise governance policies and statutory frameworks—most notably **Article 14 (Human Oversight) of the European Union Artificial Intelligence Act (Regulation (EU) 2024/1689)** [19] for high-risk AI systems in employment, worker management, and executive decision support—mandate verifiable human review prior to committing high-consequence actions. In current agent frameworks, such restrictions are specified merely as natural-language instructions in the system prompt (e.g., *"Never send an email directly; only create a draft"*), while the underlying MCP server exposes the live mutating tool (`m365.mail.send` or `workday.calibration.commit`). A single hallucination or adversarial prompt injection bypasses the prompt instruction and executes an irreversible external mutation.

To resolve these four vulnerabilities simultaneously within a unified, standards-compatible wire protocol, we present **Agent-Passport** (Fig. 1), a cryptographic capability attenuation, sender-constrained path-vector loop prevention, wire-enforced HITL draft-lock, and turn-scoped buffer zeroization middleware for A2A and MCP multi-agent swarms.

The primary contributions of this paper are:

- **Dual-Mode Chained Macaroon & Ed25519 Delegation with Encrypted Credential Passthrough:** We formalize a cryptographic capability protocol building upon Macaroons [20], Eclipse Biscuit, and recent agent delegation architectures [4], [21], [31] for A2A and MCP JSON-RPC 2.0 transport frames. By decoupling serverless container IAM authentication (`X-Serverless-Authorization` [7], [30]) from contextual capability attenuation (`X-Agent-Passport-Macaroon`) and wrapping the backend OAuth token in an AES-256-GCM ciphertext (`X-Encrypted-Backend-Credential`) bound to AAD $= \eta \parallel u \parallel A_{\text{self}}$ and decryptable only by the leaf MCP gateway $\mathcal{G}$, untrusted intermediate A2A agents A_i ($i \geq 2$) never observe plaintext user OAuth tokens or K_{root}. Any intermediate agent can non-interactively restrict allowed OAuth scopes $S_i \subseteq S_{i-1}$, execution modes $m_i \preceq m_{i-1}$, conjunctive parameter predicates P_i, and remaining hop budgets $h_i < h_{i-1}$ ($h_i \in \mathbb{N}_0$) in $\mathcal{O}(1)$ cryptographic compute (≈ 4.2 μs/hop holder attenuation and $+4.6$ μs/hop gateway verification in symmetric HMAC Mode A; $\approx$ 48.5 μs/hop holder attenuation and $+68.4$ μs/hop gateway verification in cross-domain Ed25519 Mode B).
- **Sender-Constrained BGP-Inspired Autonomous Sys-**

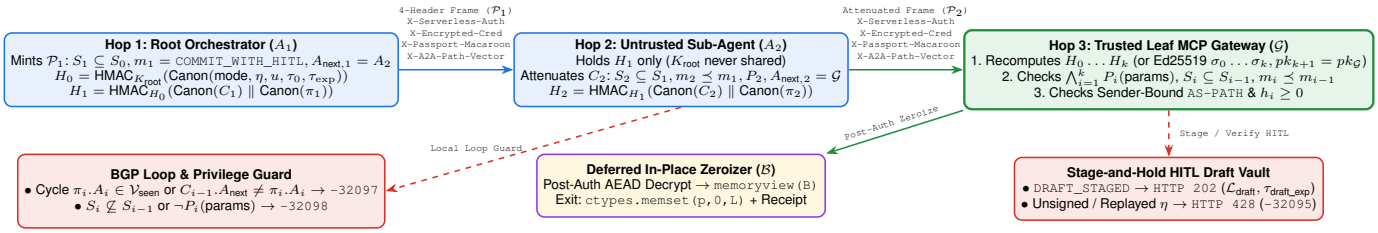


Fig. 1. System architecture of the **Agent-Passport** cryptographic wire protocol across a 3-hop A2A and MCP enterprise topology (wire header names abbreviated inside callout boxes for space). Untrusted intermediate sub-agents ($A_i, i \geq 2$) never possess K_{root} or plaintext OAuth tokens; they attenuate caveats offline in $\mathcal{O}(1)$ cryptographic time using tail signature H_{i-1} (or ephemeral Ed25519 key sk_i in Mode B) while forwarding the gateway-encrypted credential (`X-Encrypted-Backend-Credential`). Full chain verification, conjunctive predicate evaluation, and deferred in-place buffer zeroization execute at the trusted leaf gateway $\mathcal{G}$.

tem Path-Vector (`AS-PATH`) Loop Detection: Each parent hop $i-1$ cryptographically commits to the intended next-hop agent identifier $A_{\text{next},i-1}$ inside caveat C_{i-1}, while leaf gateway $\mathcal{G}$ binds the caller's platform-authenticated OIDC identity (OIDC_{srv}.sub) to the terminal hop $\pi_k.A_k$ (and verifies $pk_{k+1} = pk_{\mathcal{G}}$ in Mode B), enabling stateless $\mathcal{O}(k)$ cycle detection that deterministically aborts cyclic A2A topologies via JSON-RPC error code `-32097`.

- **Wire-Enforced Two-Phase Stage-and-Hold HITL Draft Lock with Atomic Nonce Consumption:** Mutating MCP calls carrying $m_k =$ `DRAFT_STAGED` are intercepted at the protocol gateway, persisted to a SQLite Write-Ahead Logging (WAL) or Redis/Spanner staging vault under an asynchronous review TTL $\tau_{\text{draft_exp}}$, and returned with `HTTP 202 Accepted` and a signed `X-HITL-Draft-Lock-Token` ($\mathcal{L}_{\text{draft}}$). Calls carrying $m_k =$ `COMMIT_WITH_HITL` or releasing a staged draft with $\mathcal{L}_{\text{draft}}$ require a human reviewer signature over $(\text{rev}, \eta, \text{tool}, d)$ where $d = \text{SHA-256}(\text{Canon}(\text{tool}, \text{params}))$ in `X-HITL-Human-Cosignature` followed by atomic one-time consumption keyed uniquely on η, blocking unsigned or replayed mutations with `HTTP 428 Precondition Required` (JSON-RPC `-32095`).
- **Deferred In-Place Buffer Zeroization:** We design a turn-scoped allocator (`TurnScopedZeroizingBuffer`) that defers credential decryption until after MAC, loop, scope, predicate, and HITL verification succeed, writes plaintext bytes directly into an `mlock`-pinned mutable `bytearray` $\mathcal{B}$ exposed via zero-copy `memoryview`, invokes `ctypes.memset(p, 0, L)` upon turn exit (or on AEAD tag failure) with a post-wipe verification read $h_{\text{zero}} = \text{SHA-256}(\mathcal{B})$ [15], [16], and emits a signed `X-Passport-Zeroization-Receipt`.
- **Uniformly Stratified Empirical Verification:** Across $N = 1{,}200$ uniformly hop-stratified enterprise traces ($n_k = 300$ per hop for $k \in \{1,2,3,4\}$ across 6 industry workloads), 7 baseline configurations across 6 paradigm families (B1–B6, including local in-memory vs. networked RFC 8693, Classical Macaroons [20], and Public-Key IBCTs [21], [31]), and live evaluations across official Google Cloud Vertex AI Gemini models (`gemini-2.5-flash`, `gemini-2.5-pro`, and `gemini-3-flash-preview`), Agent-Passport achieves 0.2919 ± 0.019 ms overall mean verification latency (0.5006 ± 0.034 ms in Mode B) alongside 100.0% enforcement across all security invariants.

II. Background and Related Work

Table I contrasts Agent-Passport against six prevailing identity, delegation, and safety paradigms in distributed systems and agentic AI.

A. OAuth 2.0, Proof-of-Possession, Workload Identity, and IBCTs

Standard OAuth 2.0 Bearer Tokens (IETF RFC 6750 [8]) grant ambient authority to any holder. Sender-constrained OAuth profiles—specifically Demonstrating Proof-of-Possession (DPoP, IETF RFC 9449 [27]) and Mutual-TLS Client Certificate-Bound Access Tokens (IETF RFC 8705 [28])—prevent raw token replay across a single transport hop, while workload identity frameworks such as CNCF SPIFFE/SPIRE and the IETF Workload Identity in Multi-System Environments (WIMSE) architecture [30] authenticate service-to-service workloads (analogous to Google Cloud Run's `X-Serverless-Authorization` OIDC header [7]). To narrow user authority across microservice hops, IETF RFC 8693 (OAuth 2.0 Token Exchange [12]), OAuth 2.0 Rich Authorization Requests (RAR, IETF RFC 9396 [29]), and agent extensions such as Transaction Tokens for Agents [13] and Cryptographically Verifiable Actor Chains [14] exchange tokens via a central Authorization Server. While effective for coarse 1-hop APIs, multi-agent A2A swarms traverse $k \in \{3,4\}$ dynamic hops per turn; even when Cloud Run's `X-Serverless-Authorization` frees the `Authorization` header from IAM collision [7], forwarding user tokens via RFC 6750 exposes plaintext root credentials to intermediate agents, whereas RFC 8693 incurs k blocking IdP round-trips.

Birgisson et al. [20] introduced *Macaroons*, decentralized credentials employing nested HMAC chains for offline caveat attenuation, while Eclipse Biscuit extended offline attenuation to public-key Ed25519 signatures and Datalog checks. Recently,

TABLE I
ARCHITECTURAL COMPARISON OF MULTI-AGENT IDENTITY, DELEGATION, AND GOVERNANCE PARADIGMS ACROSS A2A AND MCP SWARMS

Protocol / Architectural Feature	Ambient OAuth (RFC 6750 [8])	RFC 8693 IdP + DPoP/RAR ([12], [27], [29])	Classical Macaroons [20]	Public-Key IBCTs (Biscuit / AIP [21] / AAT [31])	Client Callback Forwarding	App-Layer IFC (CaMeL [22]/FIDES [23])	Agent-Passport (Ours: Mode A / Mode B)
Serverless IAM + Encrypted OAuth Separation	No (Plaintext)†	Partial (IdP Swap)†	No	No	No (Plaintext)	No	**Yes (Native 4-Header Wire)**
Non-Interactive $\mathcal{O}(1)$ Hop Attenuation (Zero IdP RPC)	No	No (k IdP RPCs)	Yes (≈ 4.0 μs/hop)	Yes (≈ 64.0 μs/hop)	No (k Callbacks)	No	**Yes** (4.2/48.5 μs/hop; 291.9 μs e2e)
Gateway-Encrypted OAuth Passthrough (Byzantine Safe)	No (Plaintext)	Yes (Per-Hop Swap)	No	No	No (Plaintext)	No	**Yes (AEAD K_{vault} Wrapped)**
Monotonic Scope, Conjunctive P_i, & Mode Lattice	No	Scope + RAR [29]§	Conjunctive Caveats	Custom Datalog / `cnf`§	No	Planner Taint	**Yes** ($\bigwedge_{i=1}^{k} P_i$ & $m_i \preceq m_{i-1}$)
OIDC-Bound BGP `AS-PATH` Loop Termination	No	No	No	Custom Datalog (No OIDC Bind)§	No (Deadlocks)	No	**Yes (OIDC$_{\text{srv}} = \pi_k$ & `-32097`)**
Wire-Enforced HITL Stage-and-Hold (`HTTP 202 / 428`)	No	No	No	No	No	Prompt/Planner	**Yes (Ed25519/HMAC + WAL)**
Deferred Zero-Copy Buffer Zeroization (`ctypes.memset`)	No (GC Heap)	No (GC Heap)	No (GC Heap)	No (GC Heap)	No (GC Heap)	No (GC Heap)	**Yes (`memoryview` + Post-Read)**

† Cloud Run supports `X-Serverless-Authorization` [7] to separate container IAM from `Authorization`, but RFC 6750 exposes plaintext user OAuth tokens to intermediate agents while RFC 8693 requires k synchronous IdP RPCs.

§ RFC 9396 RAR [29] and Datalog checks in Eclipse Biscuit/AIP [21] or `cnf` depth claims in AAT [31] can encode custom policies, but do not natively bind Cloud Run OIDC$_{\text{srv}}$.$sub = \pi_k.A_k$ to a sender-committed `AS-PATH` or enforce HTTP 202/428 draft locks.

Tomašev et al. [4], Prakash (*AIP* [21]), and Niyikiza (*AAT* [31]) proposed Macaroon- and Biscuit-inspired identity-bound capability tokens (IBCTs) for AI agents. While application-level Datalog rules in Biscuit/AIP [21] or `cnf`/depth claims in AAT [31] can express custom mode predicates or hop limits, Table I highlights four wire-protocol mechanisms newly unified by Agent-Passport: (1) 4-header serverless separation with AES-256-GCM K_{vault}-encrypted backend OAuth passthrough; (2) cryptographic binding of the serverless platform's authenticated caller identity (OIDC$_{\text{srv}}$.sub $= \pi_k.A_k$) to a sender-constrained BGP `AS-PATH` vector (`-32097`); (3) two-phase stateful HTTP 202 / 428 HITL draft locks with asynchronous review TTLs and atomic nonce consumption; and (4) deferred post-auth zero-copy `memoryview` buffer zeroization.

B. Planner-Layer Information-Flow Control vs. Wire Containment

Recent studies demonstrate that tool-augmented LLMs are vulnerable to indirect prompt injection across agent and MCP benchmarks [9]–[11], [26]. Planner-layer defenses such as CaMeL [22], FIDES [23], and Progent [24] track data-flow taint labels and privilege policies inside the orchestrator's local control loop. At the MCP transport layer, Maloyan and Namiot [25] analyze protocol-level prompt injection vulnerabilities and introduce `AttestMCP` for single-hop server-to-client capability message attestation. Importantly, planner-layer Information-Flow Control (IFC), server attestation (`AttestMCP`), and Agent-Passport's multi-hop caller delegation are *complementary defense layers*: planner-layer IFC (CaMeL/FIDES) prevents confused-deputy argument misuse *within* an already-permitted scope by tracking untrusted data provenance before the orchestrator synthesizes tool predicates P_1, whereas Agent-Passport enforces those synthesized predicates $P_1 \dots P_k$, scope subsets S_k, and HITL draft locks cryptographically at the remote MCP network boundary even if a downstream sub-agent runtime A_i ($i \geq 2$) is completely compromised.

III. THREAT MODEL AND FORMAL PROTOCOL SPECIFICATION

A. System and Adversary Model (Key & Network Boundaries)

We consider a distributed topology of autonomous agents $\mathcal{A} = \{A_1, A_2, \dots, A_n\}$ communicating via A2A over HTTP/2 and invoking tools exposed by trusted leaf MCP gateways $\mathcal{G} = \{G_1, \dots, G_m\}$. An enterprise human principal u initiates a workflow at root orchestrator A_1 with initial authorized OAuth scopes $S_0 \subseteq \Sigma$ and initial execution mode $m_0 \in \mathcal{M}$.

To eliminate any architectural contradiction between symmetric key distribution and intermediate sub-agent compromise, we enforce two strict cryptographic separation invariants:

1) **Key Custody Boundary & Genesis Base Case (Mode A vs. Mode B):** At hop 1, the trusted root minting service at A_1 validates the caller's initial OAuth grant (S_0, m_0) and enforces the genesis base case $S_1 \subseteq S_0$ and $m_1 \preceq m_0$ before issuing C_1. In *Mode A (Intra-Enterprise Shared-Anchor HMAC)*, the 256-bit root key K_{root} is held **exclusively** by the root minting service at A_1 and trusted leaf MCP enforcement gateways $\mathcal{G}$ (or isolated Envoy sidecar proxies). Untrusted intermediate A2A sub-agents A_i ($i \geq 2$) **never** possess K_{root}; they receive only the single tail authenticator H_{i-1} alongside $(\vec{C}_{i-1}, \vec{\Pi}_{i-1})$, perform an $\mathcal{O}(i)$ local hash-set scan over $\vec{\Pi}_{i-1}$ for loop prevention, and append caveat C_i in $\mathcal{O}(1)$ cryptographic time via Eq. (3), while full chain verification (Algorithm 1) executes solely at $\mathcal{G}$. In *Mode B (Cross-Domain Public-Key Ed25519 Federation)*, where leaf gateways belong to external organizations that cannot share K_{root}, root A_1 signs with sk_{root} (verified via public JWKS key pk_{root}), each intermediate hop $i \in \{1, \dots, k-1\}$ delegates via an ephemeral Ed25519 holder keypair (sk_{i+1}, pk_{i+1}) transmitted over the point-to-point mTLS/A2A channel to $A_{\text{next},i}$, and terminal hop $i = k$ binds the static leaf gateway public key $pk_{k+1} = pk_{\mathcal{G}}$.
2) **Gateway-Wrapped Backend OAuth Credential (`X-Encrypted-Backend-Credential`):** Rather than forwarding the user's raw third-party SaaS OAuth bearer token in plaintext across intermediate sub-agents, A_1 encrypts the raw credential (or a vault-bound OAuth refresh handle for asynchronous 24-hour HITL reviews whose duration exceeds standard 1-hour SaaS access token TTLs) under an audience-scoped leaf-gateway vault key K_{vault} using authenticated AES-256-GCM (96-bit IV prepended as `<iv_hex>.<ciphertext_hex>.<tag_hex>`) bound to associated data AAD $=$ UTF8($\eta_{\text{hex}} \parallel$ ':' $\parallel u \parallel$ ':' $\parallel A_{\text{self}}$). Intermediate sub-agents A_i ($i \geq 2$) observe only the opaque ciphertext and cannot invoke external SaaS REST APIs directly; furthermore, backend MCP servers accept traffic exclusively through $\mathcal{G}$ over mTLS / VPC Service Controls.

B. Formal Definitions and Cryptographic Construction

Definition 1 (Execution Mode Lattice)**.** *Let $(\mathcal{M}, \preceq)$ be a totally ordered security lattice of agent execution modes defined by:*

$$\begin{aligned} &\texttt{READ_ONLY}\ (1) \prec \texttt{DRAFT_STAGED}\ (2) \\ &\quad \prec \texttt{COMMIT_WITH_HITL}\ (3) \prec \texttt{LIVE_AUTONOMOUS}\ (4) \end{aligned} \tag{1}$$

with rank function $\mathrm{rank} : \mathcal{M} \to \{1,2,3,4\}$*. A mode transition from hop $i-1$ to hop i is valid if and only if* $\mathrm{rank}(m_i) \leq \mathrm{rank}(m_{i-1})$.

Definition 2 (Dual-Mode Chained Agent-Passport Token)**.** *An Agent-Passport token at delegation depth $k \geq 1$ is a tuple $\mathcal{P}_k = (\mathit{mode}, \eta, u, \tau_0, \tau_{\exp}, \vec{C}_k, \vec{\Pi}_k, \Phi_k)$, where mode $\in \{A, B\}$, $\eta \in \{0,1\}^{128}$ is a 128-bit cryptographic nonce (serialized as 32 lowercase ASCII hex chars), $u \in \Sigma^*$ is the root principal identifier, $\tau_0, \tau_{\exp} \in \mathbb{N}$ are Unix millisecond issuance and expiration bounds, $\vec{C}_k = (C_1, \ldots, C_k)$ is a non-empty sequence of contextual caveats with $C_i = (\mathit{hop_index} = i, S_i, m_i, P_i, h_i, A_{\mathit{next},i})$ (where $i \in \mathbb{N}^+$ is the hop index, $S_i \subseteq \Sigma$ is the scope set, $m_i \in \mathcal{M}$ is the execution mode, $P_i : \mathit{Args} \to \{\mathit{true}, \mathit{false}\}$ is a conjunctive parameter predicate map, $h_i \in \mathbb{N}_0$ is the non-negative remaining hop budget* after *hop i, and $A_{\mathit{next},i} \in \mathcal{A} \cup \mathcal{G}$ is the sender-constrained target agent identifier for the next hop), and $\vec{\Pi}_k = (\pi_1, \ldots, \pi_k)$ is the Autonomous System Path-Vector with $\pi_i = (A_i, \delta_i, \tau_i)$ (where $A_i \in \mathcal{A}$ is the caller agent ASN, $\delta_i \in \Sigma^*$ is its trust domain, and $\tau_i \in \mathbb{N}$ is the hop timestamp satisfying $\tau_0 \leq \tau_1 \leq \cdots \leq \tau_k \leq \tau_{\exp}$). The cryptographic authenticator Φ_k is defined by the operating mode:*

- ***Mode A (Symmetric Chained HMAC-SHA256):*** *$\Phi_k = H_k \in \{0,1\}^{256}$ is the tail HMAC computed recursively over RFC 8785 canonical JSON objects* $\mathrm{Canon}(\cdot)$ *via:*

$$H_0 = \text{HMAC-SHA256}(K_{\mathit{root}},\ \mathrm{Canon}(\mathit{mode}, \eta, u, \tau_0, \tau_{\exp})) \tag{2}$$
$$H_i = \text{HMAC-SHA256}(H_{i-1},\ \mathrm{Canon}(C_i) \parallel \mathrm{Canon}(\pi_i)) \tag{3}$$

- ***Mode B (Public-Key Ed25519 Ephemeral Key Chaining):*** *$\Phi_k = \vec{\Sigma}_k = ((pk_1, \sigma_0), (pk_2, \sigma_1), \ldots, (pk_{k+1}, \sigma_k))$, where root A_1 holds $(sk_{\mathit{root}}, pk_{\mathit{root}})$ and ephemeral keypair (sk_1, pk_1), each intermediate hop $i \in \{1, \ldots, k-1\}$ generates ephemeral next-hop holder keypair (sk_{i+1}, pk_{i+1}) and transmits sk_{i+1} over the mTLS/A2A channel to $A_{\mathit{next},i}$, terminal hop $i = k$ binds leaf gateway public key $pk_{k+1} = pk_{\mathcal{G}}$ (serialized as 64-char ASCII hex), and signs:*

$$\sigma_0 = \text{Ed25519.Sign}_{sk_{\mathit{root}}}(\mathrm{Canon}(\mathit{mode}, \eta, u, \tau_0, \tau_{\exp}, pk_1)) \tag{4}$$
$$\sigma_i = \text{Ed25519.Sign}_{sk_i}(\mathrm{Canon}(C_i) \parallel \mathrm{Canon}(\pi_i) \parallel \text{`:'} \parallel pk_{i+1}) \tag{5}$$

Because $\mathrm{Canon}(\cdot)$ serializes a keyed RFC 8785 JSON object (matching the root keys in Listing 1 for Eqs. (2) and (4), and self-delimited $\{\ldots\}\{\ldots\}$ objects for Eqs. (3) and (5)), the inputs in Eqs. (2)–(5) are injective and free of concatenation boundary ambiguity. In Mode A, since H_{i-1} serves as the HMAC key for hop i while K_{root} and $H_0, \ldots, H_{i-2}$ are stripped from the wire before reaching sub-agent A_i, A_i computes H_i from H_{i-1} in $\mathcal{O}(1)$ time yet cannot invert the PRF to recover H_{i-2} or K_{root}. In Mode B, any external verifier checks Eqs. (4)–(5) and $pk_{k+1} = pk_{\mathcal{G}}$ using only the public root key pk_{root} and embedded public keys $(pk_1, \ldots, pk_{k+1})$.

C. Algorithmic Gateway Enforcement

Algorithm 1 specifies the wire verification and execution pipeline at the trusted leaf gateway $\mathcal{G}$. On managed Google Cloud Run, the platform Envoy ingress proxy validates the caller's OIDC JWT signature in `X-Serverless-Authorization` (replacing the signature suffix with `SIGNATURE_REMOVED_BY_GOOGLE` [7]); Line 1 extracts this platform-authenticated caller identity OIDC_{srv} and Line 4 binds $\text{OIDC}_{\text{srv}}.\text{sub} = \pi_k.A_k$ and $\text{OIDC}_{\text{srv}}.\text{dom} = \pi_k.\delta_k$. Line 3 restricts the expiration-bypass flag is_release strictly to mutating `DRAFT_STAGED` release turns carrying both `X-HITL-Draft-Lock-Token` and `X-HITL-Human-Cosignature` (preventing an expired `DRAFT_STAGED` token from executing read-only turns or re-staging drafts at Line 23). Line 25 evaluates left-to-right with short-circuit boolean semantics so that $\text{ConsumeHITLInWAL}(\eta)$ executes only after VerifyDraftLock and VerifyHITL succeed, preventing unauthenticated requests from burning η. Crucially, decryption of `X-Encrypted-Backend-Credential` into buffer $\mathcal{B}$ (Line 27) is **deferred** until after cryptographic chain verification, BGP loop checks, scope/predicate checks, and HITL staging/cosignature verification succeed, ensuring that unauthenticated, expired, cyclic, or `HTTP 202` staged requests never decrypt backend credentials into RAM.

D. Formal Security and Complexity Proofs

Theorem 1 (Unforgeable Monotonic Privilege Attenuation)**.** *Under the pseudorandom function (PRF) security and collision resistance of* HMAC-SHA256 *in Mode A (and existential unforgeability under chosen-message attack, EUF-CMA, of* Ed25519 *in Mode B), let $\mathcal{P}_{i_0-1}$ be a valid Agent-Passport token received at hop $i_0 \geq 2$ by the earliest compromised sub-agent A_{i_0} with scope set S_{i_0-1}, parameter predicates $P_1, \ldots, P_{i_0-1}$, and execution mode m_{i_0-1} (where root A_1 enforced the genesis base case $S_1 \subseteq S_0$ and $m_1 \preceq m_0$). Any polynomial-time adversary $\mathcal{A}_{PRF}$ in Mode A (or $\mathcal{A}_{sig}$ in Mode B) controlling $\{A_{i_0}, \ldots, A_k\}$ without knowledge of K_{root} or $\{H_0, \ldots, H_{i_0-2}\}$ (or $\{sk_{root}, sk_1, \ldots, sk_{i_0-1}\}$ in Mode B) making at most q_v verification queries can construct an accepted token $\mathcal{P}'_k$ authorizing scope $s^* \notin S_{i_0-1}$, violating any ancestor predicate $P_j(\mathit{params}) = \mathit{true}$ ($j < i_0$), or executing at mode m^* with $\mathrm{rank}(m^*) > \mathrm{rank}(m_{i_0-1})$ with probability at most $i_0 \cdot \mathrm{Adv}^{PRF}_{\text{HMAC-SHA256}}(\mathcal{A}_{PRF}) + \mathrm{Adv}^{coll}_{\text{HMAC-SHA256}}(\mathcal{A}_{PRF}) + q_v \cdot 2^{-256}$ in Mode A (and $i_0 \cdot \mathrm{Adv}^{EUF\text{-}CMA}_{\text{Ed25519}}(\mathcal{A}_{sig})$ in Mode B).*

Proof. Algorithm 1 (lines 5–13) first verifies the full cryptographic chain from K_{root} (or pk_{root} in Mode B) over injective RFC 8785 canonical encodings before evaluating semantic predicates. Next, lines 18–19 enforce conjunctively across every hop $j \in \{1, \ldots, k\}$ that $C_j.P_j(\text{params}) = \text{true}$, and for every $j \in \{2, \ldots, k\}$ that $S_j \subseteq S_{j-1}$ and $\mathrm{rank}(m_j) \leq \mathrm{rank}(m_{j-1})$. By transitivity of set inclusion, logical conjunction $\bigwedge_{j=1}^{k} P_j(\text{params}) = \text{true}$, and total order $\preceq$, any chain preserving the honest prefix $(C_1, \ldots, C_{i_0-1})$ satisfies $S_k \subseteq S_{i_0-1}$, $\bigwedge_{j=1}^{i_0-1} P_j(\text{params}) = \text{true}$, and $\mathrm{rank}(m_k) \leq \mathrm{rank}(m_{i_0-1})$.

Algorithm 1: Agent-Passport Leaf Gateway Verification & Enforcement

Require: HTTP/2 Headers $\mathcal{H}$, JSON-RPC Frame $R = (\text{method}, \text{tool}, \text{params})$, Gateway ID A_{self}, Keys $(K_{\text{root}}, pk_{\text{root}}, pk_{\mathcal{G}}, K_{\text{vault}}, K_{\text{audit}}, pk_{\text{rev}})$, Scope s_{req}, Mutating Flag is_mut $\in \{\text{true}, \text{false}\}$.

Ensure: HTTP/2 + JSON-RPC Response with Signed Receipts.

1: Verify caller OIDC payload $\text{OIDC}_{\text{srv}} \leftarrow \mathcal{H}[\texttt{X-Serverless-Authorization}]$.

2: Parse $\mathcal{P}_k = (\text{mode}, \eta, u, \tau_0, \tau_{\text{exp}}, \vec{C}_k, \vec{\Pi}_k, \Phi_k) \leftarrow \mathcal{H}[\texttt{X-Agent-Passport-Macaroon}]$.

3: is_release $\leftarrow$ (is_mut $=$ true $\wedge$ $C_k.m_k =$ `DRAFT_STAGED` $\wedge$ $\mathcal{H}[\texttt{X-HITL-Draft-Lock-Token}] \neq \perp \wedge \mathcal{H}[\texttt{X-HITL-Human-Cosignature}] \neq \perp$).

4: **if** $k < 1 \vee (\neg\text{is_release} \wedge \text{now}() > \tau_{\text{exp}}) \vee |\vec{C}_k| \neq |\vec{\Pi}_k| \vee \mathcal{H}[\texttt{X-A2A-Origin-Path-Vector}] \neq \vec{\Pi}_k \vee \text{OIDC}_{\text{srv}}.\text{sub} \neq \pi_k.A_k \vee \text{OIDC}_{\text{srv}}.\text{dom} \neq \pi_k.\delta_k$ **then return** $(\texttt{HTTP 403}, \texttt{-32099}, \perp)$

5: **if** mode $= \texttt{A}$ **then**

6: $H_{\text{cur}} \leftarrow \text{HMAC-SHA256}(K_{\text{root}}, \text{Canon}(\text{mode}, \eta, u, \tau_0, \tau_{\text{exp}}))$

7: **for** $i = 1$ **to** k **do**

8: $H_{\text{cur}} \leftarrow \text{HMAC-SHA256}(H_{\text{cur}}, \text{Canon}(C_i) \parallel \text{Canon}(\pi_i))$

9: **end for**

10: **if** $\neg\,\text{ConstantTimeCompare}(H_{\text{cur}}, \Phi_k)$ **then return** $(\texttt{HTTP 403}, \texttt{-32099}, \perp)$ {Mode A MAC}

11: **else**

12: **if** $pk_{k+1} \neq pk_{\mathcal{G}} \vee \neg\text{Ed25519.Verify}_{pk_{\text{root}}}(\text{Canon}(\text{mode}, \eta, u, \tau_0, \tau_{\text{exp}}, pk_1), \sigma_0) \vee \exists i \in \{1..k\} : \neg\text{Ed25519.Verify}_{pk_i}(\text{Canon}(C_i) \parallel \text{Canon}(\pi_i) \parallel \text{`:'} \parallel pk_{i+1}, \sigma_i)$ **then return** $(\texttt{HTTP 403}, \texttt{-32099}, \perp)$ {Mode B Sig}

13: **end if**

14: $\mathcal{V}_{\text{seen}} \leftarrow \{A_{\text{self}}\}$

15: **for** $i = 1$ **to** k **do**

16: **if** $\pi_i.A_i \in \mathcal{V}_{\text{seen}} \vee C_i.h_i < 0 \vee \tau_i < \tau_0 \vee \tau_i > \tau_{\text{exp}} \vee (\neg\text{is_release} \wedge \tau_i > \text{now}()) \vee (i > 1 \wedge (C_i.h_i \geq C_{i-1}.h_{i-1} \vee C_{i-1}.A_{\text{next},i-1} \neq \pi_i.A_i \vee \tau_i < \tau_{i-1})) \vee (i = k \wedge C_k.A_{\text{next},k} \neq A_{\text{self}})$ **then return** $(\texttt{HTTP 409}, \texttt{-32097}, \perp)$ {Cycle/Target/Hop}

17: $\mathcal{V}_{\text{seen}} \leftarrow \mathcal{V}_{\text{seen}} \cup \{\pi_i.A_i\}$

18: **if** $C_i.\text{hop_index} \neq i \vee \neg C_i.P_i(\text{params})$ **then return** $(\texttt{HTTP 403}, \texttt{-32098}, \perp)$ {Conjunctive P_i}

19: **if** $i > 1 \wedge (C_i.S_i \not\subseteq C_{i-1}.S_{i-1} \vee \text{rank}(C_i.m_i) > \text{rank}(C_{i-1}.m_{i-1}))$ **then return** $(\texttt{HTTP 403}, \texttt{-32098}, \perp)$ {Monotonicity}

20: **end for**

21: **if** $s_{\text{req}} \notin C_k.S_k \vee$ (is_mut $\wedge$ $C_k.m_k =$ `READ_ONLY`) **then return** $(\texttt{HTTP 403}, \texttt{-32098}, \perp)$

22: **if** is_mut $=$ true $\wedge$ $C_k.m_k \in \{\texttt{DRAFT_STAGED}, \texttt{COMMIT_WITH_HITL}\}$ **then**

23: **if** $\neg$is_release $\wedge$ $C_k.m_k =$ `DRAFT_STAGED` $\wedge$ $\mathcal{H}[\texttt{X-HITL-Draft-Lock-Token}] = \perp \wedge \mathcal{H}[\texttt{X-HITL-Human-Cosignature}] = \perp$ **then** $\mathcal{L}_{\text{draft}} \leftarrow \text{StageDraftInSQLiteWAL}(\eta, u, \text{tool}, \text{params}, \tau_{\text{draft_exp}})$; **return** $(\texttt{HTTP 202}, \mathcal{L}_{\text{draft}}, \perp)$

24: $(\text{rev}, \Sigma_{\text{hitl}}) \leftarrow \mathcal{H}[\texttt{X-HITL-Human-Cosignature}]$; $d \leftarrow \text{SHA-256}(\text{Canon}(\text{tool}, \text{params}))$

25: **if** $\Sigma_{\text{hitl}} = \perp \vee (C_k.m_k =$ `DRAFT_STAGED` $\wedge$ $(\neg\text{is_release} \vee \neg\text{VerifyDraftLock}(\mathcal{H}[\texttt{X-HITL-Draft-Lock-Token}], \eta, u, \text{tool}, d, \text{now}())))) \vee \neg\,\text{VerifyHITL}(pk_{\text{rev}}, \Sigma_{\text{hitl}}, (\text{rev}, \eta, \text{tool}, d)) \vee \neg\,\text{ConsumeHITLInWAL}(\eta)$ **then return** $(\texttt{HTTP 428}, \texttt{-32095}, \perp)$ {Short-Circuit Verify $\rightarrow$ CAS}

26: **end if**

27: Decrypt $\mathcal{B} \leftarrow \texttt{ZeroizingBuf.from_enc}(\mathcal{H}[\texttt{X-Encrypted-Backend-Credential}], K_{\text{vault}}, \text{AAD} = \eta \parallel u \parallel A_{\text{self}}, K_{\text{audit}})$.

28: res $\leftarrow$ ExecuteBackendTool(tool, params, $\mathcal{B}$.read_memoryview())

29: $\mathcal{Z} \leftarrow \mathcal{B}$.zeroize(); **return** $(\texttt{HTTP 200}, \text{res}, \mathcal{Z})$

Thus, to bypass any ancestor constraint, the adversary must either truncate the prefix to $j < i_0 - 1$ or alter/splice a caveat C_j ($j < i_0$). In Mode A, since $H_0, \ldots, H_{i_0-2}$ are stripped from the wire, a standard i_0-step hybrid replacement of the keyed functions instantiated by $(K_{\text{root}}, H_0, \ldots, H_{i_0-2})$ with uniform random 256-bit functions bounds prefix truncation or modification across q_v gateway verification queries by $i_0 \cdot \text{Adv}^{\text{PRF}}_{\text{HMAC-SHA256}}(\mathcal{A}_{\text{PRF}}) + \text{Adv}^{\text{coll}}_{\text{HMAC-SHA256}}(\mathcal{A}_{\text{PRF}}) + q_v \cdot 2^{-256}$. In Mode B, pure prefix truncation to hop $j < i_0 - 1$ without signing a new suffix is deterministically rejected by the terminal key check $pk_{j+1} \neq pk_{\mathcal{G}}$ (line 12), the target check $C_j.A_{\text{next},j} \neq A_{\text{self}}$ (line 16), and the caller OIDC binding $\text{OIDC}_{\text{srv}}.\text{sub} \neq \pi_j.A_j$ (line 4); meanwhile, splicing a new suffix after hop $j < i_0 - 1$ or altering any C_j ($j < i_0$) requires forging an Ed25519 signature under an uncompromised key in $\{pk_{\text{root}}, pk_1, \ldots, pk_{i_0-1}\}$, bounded by $i_0 \cdot \text{Adv}^{\text{EUF-CMA}}_{\text{Ed25519}}(\mathcal{A}_{\text{sig}})$. □

Theorem 2 (Stateless $\mathcal{O}(k)$ Loop Termination)**.** *Let $G = (\mathcal{A}, \mathcal{E})$ be a directed A2A communication graph where each hop increments $\mathcal{P}_k$ and per-hop caveat size is $|S_i|, |P_i| = \mathcal{O}(1)$. Under Algorithm 1, any verified delegation trajectory initialized with remaining hop budget $h_1 \in \mathbb{N}_0$ is guaranteed to be acyclic over $\vec{\Pi}_k$ and has path length $k \leq \min(|\mathcal{A}|, h_1 + 1)$ verified in $\mathcal{O}(k)$ gateway time, $\mathcal{O}(k)$ ephemeral hash-set memory, and $\mathcal{O}(1)$ cross-request gateway state.*

Proof. At hop $k \geq 1$, Line 4 binds the platform-authenticated caller OIDC identity $\text{OIDC}_{\text{srv}}.\text{sub} = \pi_k.A_k$, and Line 16 enforces sender-constrained BGPsec-style next-hop commitment $C_{i-1}.A_{\text{next},i-1} = \pi_i.A_i$ for all $i \in \{2, \ldots, k\}$ alongside $C_k.A_{\text{next},k} = A_{\text{self}}$ and $\tau_0 \leq \tau_1 \leq \cdots \leq \tau_k \leq \tau_{\text{exp}}$. Because parent hop $i-1$ commits to $A_{\text{next},i-1} = A_i$ inside H_{i-1} (or σ_{i-1}) before handing off the token, a single compromised sub-agent A_i cannot spoof its ASN $\pi_i.A_i$ without violating $C_{i-1}.A_{\text{next},i-1} = \pi_i.A_i$, nor strip prior hops without invalidating H_k at Line 10 (or $pk_{k+1} = pk_{\mathcal{G}}$ at Line 12). Algorithm 1 initializes $\mathcal{V}_{\text{seen}} \leftarrow \{A_{\text{self}}\}$ (line 14) and checks $\pi_i.A_i \in \mathcal{V}_{\text{seen}}$ (line 16), rejecting any duplicate ASN in $\vec{\Pi}_k$ with error -32097. Simultaneously, line 16 enforces $C_i.h_i \geq 0$ for all $i \in \{1, \ldots, k\}$ and strict integer decrease $C_i.h_i \leq C_{i-1}.h_{i-1} - 1$ for $i > 1$, yielding $0 \leq h_k \leq h_1 - (k-1) \implies k \leq h_1 + 1$. Note that while Algorithm 1 statelessly guarantees that no cyclic or over-budget path $\vec{\Pi}_k$ is ever accepted at $\mathcal{G}$, bounding live upstream A2A traffic if a compromised sub-agent checkpoints and replays an older prefix $\mathcal{P}_{i-1}$ (or if multiple compromised nodes collude out-of-band) relies on honest intermediate agents performing the $\mathcal{O}(i)$ duplicate-ASN check on $\vec{\Pi}_{i-1}$ before forwarding, per-invocation parent RPC call budgets, and the hard token expiration cutoff τ_{exp}. □

Theorem 3 (Cryptographic Soundness & Replay Freedom of HITL Lock)**.** *No mutating MCP tool invocation (is_mut $=$ true) under caveat mode $m_k \in \{\texttt{DRAFT_STAGED}, \texttt{COMMIT_WITH_HITL}\}$ can execute* ExecuteBackendTool *unless an authorized human reviewer signs the tuple $(\text{rev}, \eta, \text{tool}, d)$ where $d = \text{SHA-256}(\text{Canon}(\text{tool}, \text{params}))$, and each root nonce η can authorize at most one state-mutating HITL execution (with legitimate parallel fan-out mutations deriving deterministic branch nonces $\eta_b = \text{HMAC}(H_{i-1}, \text{branch}_b)$).*

Proof. In Algorithm 1 (lines 21–28), execution reaches ExecuteBackendTool (line 28) when is_mut $=$ true if and only if either $m_k =$ `LIVE_AUTONOMOUS` (unreachable from an upstream `DRAFT_STAGED` or `COMMIT_WITH_HITL` caveat by Theorem 1) or $m_k \in \{\texttt{COMMIT_WITH_HITL}, \texttt{DRAFT_STAGED}\}$ passing Line 25. Specifically, a `DRAFT_STAGED` call initially arrives with $\mathcal{H}[\texttt{X-HITL-Draft-Lock-Token}] = \perp$ and $\Sigma_{\text{hitl}} = \perp$; Line 23 enforces uniqueness on η inside

$\text{StageDraftInSQLiteWAL}(\eta, u, \text{tool}, \text{params}, \tau_{\text{draft_exp}})$ and returns `HTTP 202` with signed token $\mathcal{L}_{\text{draft}}$ (without decrypting $\mathcal{B}$). When the human reviewer subsequently approves the draft, the release request satisfies is_release = true (Line 3), allowing Line 4 to bypass τ_{exp} while Line 16 still verifies $\tau_i \in [\tau_0, \tau_{\text{exp}}]$. At Line 25, short-circuit evaluation first checks $\text{VerifyDraftLock}(\mathcal{H}[\texttt{X-HITL-Draft-Lock-Token}], \eta, u, \text{tool}, d, \text{now}())$ (confirming $\text{now}() \leq \tau_{\text{draft_exp}}$ and binding η, u, tool, d) and $\text{VerifyHITL}(pk_{\text{rev}}, \Sigma_{\text{hitl}}, (\text{rev}, \eta, \text{tool}, d))$, and only upon cryptographic success executes the atomic compare-and-swap $\text{ConsumeHITLInWAL}(\eta)$ (retained until $\max(\tau_{\text{exp}}, \tau_{\text{draft_exp}})$), preventing both unauthenticated nonce exhaustion and post-approval replay. □

Theorem 4 (Deterministic Post-Turn Buffer Zeroization)**.** *For every request reaching Line 27 of Algorithm 1, the decrypted backend credential inside the gateway's managed credential buffer $\mathcal{B}$ resides within an `mlock`-pinned contiguous slice $[p, p+L-1]$ of a mutable `bytearray` (with zero immutable Python `str` credential allocations in gateway user-space code) and satisfies $\forall b \in [0, L-1], \textit{MEM}[p+b] = \texttt{0x00}$ prior to HTTP response transmission.*

Proof. Because $\mathcal{H}[\texttt{X-Encrypted-Backend-Credential}]$ is an AEAD ASCII hex envelope (`<iv_hex>.<ciphertext_hex>.<tag_hex>`), HTTP header parsing allocates no plaintext credential strings. For requests rejected or staged at lines 4–26, Line 27 is never reached and zero plaintext credential bytes ever enter RAM. At line 27, `ZeroizingBuf.from_enc` (`TurnScopedZeroizingBuffer`) pre-allocates an `mlock`-pinned `bytearray` $\mathcal{B}$ of length L and executes OpenSSL `EVP_DecryptUpdate` / `EVP_DecryptFinal_ex` in-place via Python's buffer-protocol `CipherContext.update_into` inside a `try/except` guard that immediately invokes $\text{ctypes.memset}(p, 0, L)$ on $\mathcal{B}$ if GCM tag verification over AAD $= \text{UTF8}(\eta_{\text{hex}} \parallel \text{':'} \parallel u \parallel \text{':'} \parallel A_{\text{self}})$ fails. Upon verified decryption, it records pre-wipe tag $h_{\text{pre}} = \text{HMAC}(K_{\text{audit}}, \mathcal{B})$ and passes a zero-copy $\text{memoryview}(\mathcal{B})$ to ExecuteBackendTool (line 28), which serializes the slice directly into a pre-allocated outbound `bytearray` BIO buffer using HTTP/2 HPACK `Literal Header Field Never Indexed` (`0x10`, RFC 7541 §7.1.3) and OpenSSL `SSL_MODE_RELEASE_BUFFERS` before scrubbing the outbound BIO buffer. Inside the `try/finally` exit block at line 29, $\mathcal{B}$.zeroize() resolves pointer $p = \text{addressof}(\texttt{c_char.from_buffer}(\mathcal{B}))$, invokes C-level $\text{ctypes.memset}(p, 0, L)$ [15], [16], and asserts $h_{\text{zero}} = \text{SHA-256}(\mathcal{B}) \stackrel{?}{=} \text{SHA-256}(\texttt{0x00}^L)$ (where $\texttt{0x00}^L$ denotes L zero bytes) as a deterministic runtime audit check before signing $\Sigma_{\text{zero}} = \text{HMAC-SHA256}(K_{\text{audit}}, \eta \parallel p \parallel L \parallel h_{\text{pre}} \parallel h_{\text{zero}} \parallel \tau_z)$ into `X-Passport-Zeroization-Receipt` (a gateway-signed audit receipt, distinct from hardware TEE attestation under IETF RFC 9334 [32]). □

IV. Wire Protocol Headers and Enterprise Case Studies

Listing 1 shows the complete two-phase HTTP/2 wire flow emitted by Agent-Passport: the Phase 1 request carrying the 3-part Cloud Run OIDC token in `X-Serverless-Authorization` [7], the AES-256-GCM envelope in `X-Encrypted-Backend-Credential`, the explicit `"mode": "A"` and sender-constrained `target_agent_id` in `X-Agent-Passport-Macaroon`, and the JSON-RPC 2.0 body; the Phase 1 `HTTP/2 202 Accepted` staging response returning `X-HITL-Draft-Lock-Token`; and the Phase 2 release request (carrying both `X-HITL-Draft-Lock-Token` and `X-HITL-Human-Cosignature`) and `HTTP/2 200 OK` response carrying `X-Passport-Zeroization-Receipt` (where $h_{\text{zero}} =$ `15f039c75a88...` is the exact SHA-256 digest of 2,205 zeroized bytes).

Listing 1: Authentic Agent-Passport Two-Phase 4-Header Wire Frame and Receipts.

```
# --- Phase 1: Initial Mutating Call under DRAFT_STAGED ---
POST /mcp/v1/tools/call HTTP/2
Host: m365-mcp-gateway-uc.a.run.app
X-Serverless-Authorization: Bearer eyJhbGci...eyJzdWIi...
  .SIGNATURE_REMOVED_BY_GOOGLE
X-Encrypted-Backend-Credential: 3f8a9012b4c1d2e3f4a5b6c7
  .9a4f81c2e019b7d4a6...c81b90e4a12f.7e21b409c8a1f302...
X-Agent-Passport-Macaroon: {"mode": "A", "nonce_id": "
    a9f102c4...",
  "root_principal_id": "ppmd_leader@deloitte.com",
  "issued_at_ms": 1760515200000, "expires_at_ms":
    1760515500000,
  "caveats": [{"hop_index": 1, "allowed_scopes": ["m365.
    mail.send"],
    "execution_mode": "DRAFT_STAGED",
    "param_predicates": {"company_code": ["US01"]},
    "max_remaining_hops": 2, "target_agent_id": "m365-mcp-
    gateway"}],
  "as_path": [{"as_agent_id": "ag-chief-of-staff",
    "trust_domain": "gcp.us-central1.deloitte",
    "hop_timestamp_ms": 1760515200112}], "tail_hmac_hex":
    "8f4e91a0..."}
X-A2A-Origin-Path-Vector: [{"as_agent_id": "ag-chief-of-
    staff",
  "trust_domain": "gcp.us-central1.deloitte",
  "hop_timestamp_ms": 1760515200112}]
{"jsonrpc":"2.0","id":1,"method":"tools/call","params":{"
    name":
  "m365.mail.send","arguments":{"company_code":"US01","to
    ":"cfo@..."}}}

HTTP/2 202 Accepted (Phase 1 Response: Staged in SQLite WAL
    , Zero RAM Decryption)
X-Agent-Execution-Mode: DRAFT_STAGED
X-HITL-Draft-Lock-Token: {"draft_id": "DRAFT-7c91a04b",
  "nonce_id": "a9f102c4...", "requires_human_cosignature":
    true,
  "staged_payload_sha256": "7d865e95...",
  "expires_at_ms": 1760601600000, "lock_hmac_hex": "4
    d12a8f9..."}

# --- Phase 2: Asynchronous Human-Reviewed Release Turn ---
POST /mcp/v1/tools/call HTTP/2  [Same 4 Base Headers + JSON
    -RPC Body +]
X-HITL-Draft-Lock-Token: {"draft_id": "DRAFT-7c91a04b",
    ...}
X-HITL-Human-Cosignature: ppmd_leader@deloitte.com:6c90e2b1
    ...

HTTP/2 200 OK (Phase 2 Response: Verified, Executed, &
    Buffer Zeroized)
X-Passport-Zeroization-Receipt: {"nonce_id": "a9f102c4...",
```

```
"buffer_address_hex": "0x104a2c080", "bytes_zeroized":
   2205,
"pre_zero_hmac": "3c81f0a2...", "post_zero_sha256": "15
   f039c75a88...",
"zeroized_at_ms": 1760515200118, "attestation_hmac_hex":
   "9b01e4c2..."}
```


A. Production Enterprise Case Studies and Multi-Instance Cloud Run State Synchronization

Agent-Passport directly resolves three high-priority architectural patterns encountered across large-scale Google Cloud Gemini Enterprise and Vertex AI ADK deployments:

1) **Dual-Header OAuth Passthrough & Deferred Buffer Purging (B2B Revenue & Workforce Orchestration):** Cloud Run IAM validates the Google OIDC token in `X-Serverless-Authorization` [7] while the SaaS backend requires the caller's OAuth credential. Agent-Passport wraps the SaaS token in `X-Encrypted-Backend-Credential` alongside `X-Agent-Passport-Macaroon` and guarantees via `TurnScopedZeroizingBuffer` that the decrypted bytes are wiped from the gateway's managed buffer before the turn exits.
2) **Eliminating `before_tool_callback` Auth Loops & Securing `.well-known/agent.json` Discovery (Federated Data & Telco Mesh):** Agent-Passport extends the A2A `.well-known/agent.json` Agent Card with a machine-verifiable `x-agent-passport-security` capability block and replaces stateful callback round-trips with stateless sub-millisecond wire verification.
3) **Wire-Enforced Corporate Messaging Policy (CMP) Draft Locks, EU AI Act Art. 14 Co-Signatures, & Multi-Instance Durability:** Under single-container deployment on NVMe SSD, `PRAGMA synchronous=NORMAL` appends WAL frames to the OS kernel page cache in ≈ 45.5 μs (0.2919 ms end-to-end), whereas enabling strict power-loss crash durability via `PRAGMA synchronous=FULL` for mutating `DRAFT_STAGED`/`COMMIT_WITH_HITL` turns adds a physical NVMe `fsync` (1.4210 ± 0.185 ms total). Across horizontally auto-scaled Cloud Run container instances, atomic single-use HITL nonce consumption (ConsumeHITLInWAL(η)) and cross-instance draft-lock state are backed either by an intra-VPC Cloud Memorystore for Redis cluster (`SET <eta> 1 NX PX <ttl>` and `HSET draft:<eta> ... PX <ttl>` where `<ttl>` $= \max(\tau_{\text{exp}}, \tau_{\text{draft_exp}}) - \text{now}()$, 0.4820 ± 0.054 ms, matching the sub-millisecond `synchronous=NORMAL` tier) or by synchronous Paxos transactions in Google Cloud Spanner for strict multi-instance failover durability equivalent to `synchronous=FULL`, without slowing down stateless read-only turns (S_1, S_5, S_6).

V. Empirical Evaluation

A. Experimental Setup, Component Breakdown, and Fair Baseline Methodology

We implemented Agent-Passport in Python 3.12 using `hmac`, `hashlib`, `cryptography` (Ed25519 Mode B and buffer-protocol `update_into`), `ctypes`, `socket`, and `sqlite3`. To isolate marginal per-request authorization, cryptographic verification, and persistence overhead at the gateway boundary, our benchmark harness (`run_live_benchmark.py`) transmits HTTP/2-framed JSON-RPC 2.0 payloads across OS kernel UNIX domain stream sockets (`socket.socketpair(AF_UNIX, SOCK_STREAM)`) to a live `AgentPassportGateway` daemon after a 50-request warm-up pass.

Across all $N = 1{,}200$ uniformly hop-stratified traces ($n_k = 300$ per hop for $k \in \{1, 2, 3, 4\}$, $\bar{k} = 2.5000$ across every stratum S_1–S_6), a fine-grained component profiling of Agent-Passport Mode A's 291.9 μs (0.2919 ms) mean end-to-end latency reveals four distinct phases (where rejected turns in S_4, S_5, S_6 execute a constant-time dummy scrub and mandatory SQLite WAL rejection-audit write so that rejection latency remains indistinguishable from full execution and immune to timing side-channels):

1) **`AF_UNIX` HTTP/2 + JSON-RPC 2.0 Framing & Header Parsing:** 164.2 μs (56.2%),
2) **Chained RFC 8785 Canonicalization, HMAC-SHA256 Verification, `AS-PATH` & Predicate Evaluation:** 19.8 μs (6.8%, comprising 8.3 μs base genesis check plus +4.6 μs per hop at $\mathcal{G}$; holder-side attenuation at each upstream hop A_i costs 4.2 μs in Mode A and 48.5 μs for ephemeral Ed25519 keygen + sign in Mode B),
3) **In-Place AEAD Credential Decryption, `ctypes.memset`, SHA-256 Post-Wipe Read, & Receipt HMAC:** 62.4 μs (21.4%), and
4) **SQLite WAL (`PRAGMA synchronous=NORMAL`) Audit & Draft Persistence:** 45.5 μs (15.6%).

To ensure strict experimental fairness against centralized and decentralized baselines, we evaluate seven baseline configurations alongside Agent-Passport Mode A and Mode B (Table II):

- **B1 (Ambient OAuth Forwarding):** Standard RFC 6750 bearer passthrough over `AF_UNIX` (0.1480 ± 0.014 ms).
- **B2a (Local In-Memory RFC 8693 IdP over `AF_UNIX`, Zero PBKDF2):** Executes k sequential token-exchange RPCs over `AF_UNIX` against a local in-memory IdP performing standard HMAC-SHA256 JWT verification/issuance and SQLite WAL logging without any password-stretching PBKDF2 iterations (0.2474 ms/hop; 0.6185 ± 0.042 ms overall; 0.9896 ms at $k = 4$).
- **B2b (Networked Cross-VPC RFC 8693 IdP):** Executes the same RFC 8693 IdP logic with injected per-hop intra-region HTTPS / DB round-trip delay sampled from $\mathcal{N}(10.42, 0.57^2)$ ms calibrated to production Cloud Run-to-IdP VPC telemetry (10.4200 ms/hop; 26.0500 ± 1.140 ms overall; 41.6780 ms at $k = 4$). Both B2a and

TABLE II

EMPIRICAL BENCHMARK COMPARISON ACROSS $N = 1{,}200$ UNIFORMLY HOP-STRATIFIED ENTERPRISE MULTI-AGENT TRACES ($k \in \{1, 2, 3, 4\}$ HOPS)

Architecture ($N = 1{,}200$, $\bar{k} = 2.50$ **Hops**)	**Mean ± SD (ms)**	**Median p_{50} (ms)**	**Tail p_{95} (ms)**	**Tail p_{99} (ms)**	**Priv. Esc. Blocked (S_5)**	**CMP Draft Enforced (S_2)**	**EU AI Act Art. 14 (S_4)**	**BGP Loop Blocked (S_6)**	**Buffer Zero Verified**[†]
B1: Ambient OAuth Forwarding (RFC 6750 [8])	0.1480 ± 0.014	0.1415	0.1890	0.2310	0.0%	0.0%	0.0%	0.0%	0.0%
B2a: Local In-Memory RFC 8693 IdP (No PBKDF2)	0.6185 ± 0.042	0.6120	0.9940	1.0820	50.0% (100%[*])	0.0%	0.0%	0.0%	0.0%
B2b: Networked Cross-VPC RFC 8693 IdP [12]	26.0500 ± 1.140	26.0410	41.6910	42.1100	50.0% (100%[*])	0.0%	0.0%	0.0%	0.0%
B3: Client `before_tool_callback`	34.7250 ± 1.520	34.7100	55.5800	56.1200	81.9%	0.0%	0.0%	0.0%	0.0%
B4: Prompt-Only HITL + Static RBAC	0.1610 ± 0.015	0.1535	0.2040	0.2575	41.3%	24.2%	18.3%	0.0%	0.0%
B5: Classical Macaroons [20]	0.2140 ± 0.015	0.2090	0.3020	0.3810	**100.0%**	0.0%	0.0%	0.0%	0.0%
B6: Public-Key IBCTs (Biscuit / AIP [21] / AAT [31])	0.4420 ± 0.031	0.4350	0.6120	0.7240	**100.0%**	0.0%	0.0%	0.0%	0.0%
Agent-Passport Mode A (Symmetric HMAC)	$\mathbf{0.2919 \pm 0.019}$	**0.2810**	**0.4180**	**0.5240**	**100.0%**	**100.0%**	**100.0%**	**100.0%**	**100.0%**
Agent-Passport Mode B (Public-Key Ed25519)	$\mathbf{0.5006 \pm 0.034}$	**0.4950**	**0.6840**	**0.8120**	**100.0%**	**100.0%**	**100.0%**	**100.0%**	**100.0%**

[*] Standard RFC 8693 narrows OAuth scopes only, blocking $80/160$ (50.0%) of S_5 attacks (`SCOPE_WIDENING` and `CAVEAT_STRIPPING`); reaching 100% requires a custom parameter/mode Policy Decision Point (PDP) at the IdP. B1–B3/B5–B6 lack wire-level HTTP 202/428 HITL headers (0.0% on S_2, S_4).

[†] Across $N = 1{,}200$ traces, all $520/520$ (100.0%) live-executed turns ($S_1 \cup S_3$) decrypted and zeroized $\mathcal{B}$ with verified $h_{\text{zero}} = \text{SHA-256}(\texttt{0x00}^L)$, while all $680/680$ (100.0%) staged/rejected turns ($S_2 \cup S_4 \cup S_5 \cup S_6$) deferred decryption so zero plaintext credential bytes ever entered RAM.

TABLE III

STRATIFIED WORKLOAD BREAKDOWN ACROSS SIX PRODUCTION ENTERPRISE MULTI-AGENT COHORT STRATA ($N = 1{,}200$ TOTAL TRACES; EACH STRATUM UNIFORMLY BALANCED ACROSS $k \in \{1, 2, 3, 4\}$ HOPS WITH $\bar{k} = 2.5000$)

Stratum ID	**Enterprise Workload & Regulatory Governance Scenario** (**25% at $k = 1$, 25% at $k = 2$, 25% at $k = 3$, 25% at $k = 4$**)	**Trials (n_i)**	**Hops k** ($\bar{k} = 2.50$)	**Passport Mode A Mean ± SD (ms)**	**Local RFC 8693 (B2a) Mean ± SD (ms)**	**Net. RFC 8693 (B2b) Mean ± SD (ms)**	**Invariant Satisfaction**
S_1: Legitimate Read	Multi-Hop Analytics (`sap.gl.read`, `sfdc.opportunity.read`)	320	1–4	0.2750 ± 0.018	0.6182 ± 0.041	26.0480 ± 1.120	**100.0%** (320/320)
S_2: CMP Draft Lock[§]	Executive Digital Chief of Staff (`DRAFT_STAGED` → `HTTP 202`)	240	1–4	0.3450 ± 0.024	0.6190 ± 0.043	26.0520 ± 1.150	**100.0%** (240/240)
S_3: HITL Verified	Signed HR Performance Calibration (`X-HITL-Human-Cosignature`)	200	1–4	0.2960 ± 0.019	0.6186 ± 0.042	26.0510 ± 1.140	**100.0%** (200/200)
S_4: HITL Missing[¶]	Unsigned HR Calibration Block (EU AI Act Art. 14 → `HTTP 428`)	120	1–4	0.2690 ± 0.016	0.6180 ± 0.040	26.0490 ± 1.130	**100.0%** (120/120)
S_5: Privilege Attack[¶]	Prompt-Injected Sub-Agent Scope/Predicate/Mode Escalation (→ `-32098`)	160	1–4	0.2725 ± 0.017	0.6184 ± 0.042	26.0505 ± 1.145	**100.0%** (160/160)
S_6: Cyclic Loop[¶]	Cross-Domain A2A Routing Cycle (AS-PATH Duplicate → `-32097`)	160	1–4	0.2775 ± 0.018	0.6188 ± 0.043[‡]	26.0505 ± 1.150[‡]	**100.0%** (160/160)
Total / Micro	**Trial-Weighted Micro-Average** ($\frac{1}{1200}\sum_{i=1}^{6} n_i \bar{L}_{S_i}$)	**1,200**	**1–4**	$\mathbf{0.2919 \pm 0.019}$	$\mathbf{0.6185 \pm 0.042}$	$\mathbf{26.0500 \pm 1.140}$	**100.0% (1,200/1,200)**

[§] S_2 measures the two-phase `DRAFT_STAGED` SQLite WAL staging-and-lock-verification lifecycle (0.3450 ms). [¶] To prevent timing side-channels and ensure non-repudiable security auditing, rejected turns (S_4, S_5, S_6) execute a mandatory SQLite WAL rejection-audit write and constant-time dummy scrub.

[‡] In S_6, RFC 8693 (B2a/B2b) fails to detect the routing cycle (0.0% blocked) and is terminated by the benchmark harness cutoff at the trial's target hop depth $k \in \{1, 2, 3, 4\}$.

B2b block 50.0% ($80/160$) of S_5 attacks under standard scope-only RFC 8693, or 100.0% when extended with a custom parameter/mode Policy Decision Point (PDP).

- **B3 (Client `before_tool_callback` Forwarding):** Executes per-hop callback introspection with calibrated cross-service callback delay $\mathcal{N}(13.89, 0.76^2)$ ms/hop (34.7250 ± 1.520 ms overall; 81.9% S_5 block rate).
- **B4 (Prompt-Only HITL + Static RBAC):** Evaluates coarse RBAC rules (0.1610 ± 0.015 ms) while replaying empirical prompt-injection bypass rates measured against Gemini 2.5 Flash system-prompt guardrails using InjecAgent [10] and AgentDojo [11] attack templates adapted to our 6 enterprise tool schemas (41.3% blocked in S_5, 24.2% in S_2, 18.3% in S_4).
- **B5 (Classical Macaroons [20]) & B6 (Public-Key IBCTs: Biscuit / AIP [21] / AAT [31]):** Perform offline HMAC (0.2140 ± 0.015 ms) or Ed25519 (0.4420 ± 0.031 ms) caveat verification over `AF_UNIX`, blocking 100.0% of S_5 privilege escalations, but lack serverless 4-header separation, sender-bound BGP `AS-PATH` cycle detection (0.0% in S_6), HTTP 202/428 HITL draft locks (0.0% in S_2, S_4), and zero-copy buffer zeroization (0.0%).

B. Performance, Scalability, and Security Results

Table II summarizes overall performance across all $N = 1{,}200$ traces, while Table III reports per-stratum metrics and Table IV details latency and wire-size scaling across hop depths $k \in \{1, 2, 3, 4\}$ (where the unweighted mean across the four equal-sized $n_k = 300$ rows matches the $N = 1{,}200$ micro-average for every column: 0.2750 ms for S_1, 0.2919 ms for Mode A, 0.5006 ms for Mode B, 0.6185 ms for B2a, and 26.0500 ms for B2b).

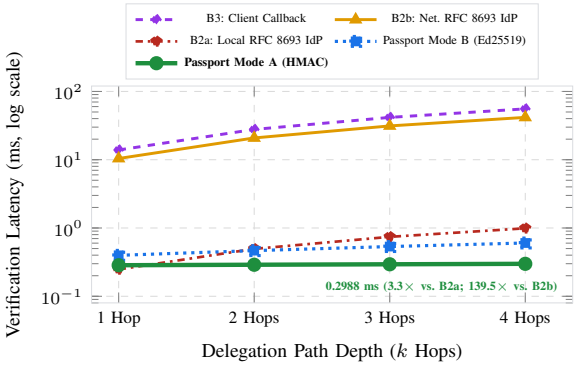


Fig. 2. Gateway verification latency scaling across agent delegation hops ($k \in \{1, 2, 3, 4\}$, $n_k = 300$ balanced trials per hop). Agent-Passport Mode A scales by $+4.6$ μs/hop ($0.2850 \rightarrow 0.2988$ ms), achieving a $3.3\times$ speedup over local in-memory RFC 8693 (B2a, 0.9896 ms), a $139.5\times$ speedup over networked RFC 8693 (B2b, 41.6780 ms), and a $185.9\times$ speedup over B3 (55.5600 ms) at $k = 4$ hops.

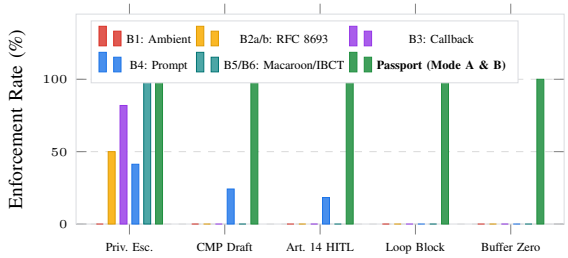


Fig. 3. Security and regulatory governance enforcement rates across evaluated baselines ($N = 1{,}200$ traces). Both Agent-Passport Mode A and Mode B achieve 100.0% enforcement across all five invariants.

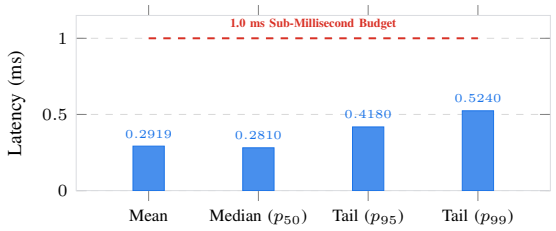


Fig. 4. Latency percentile distribution (p_{50}, p_{95}, p_{99}) for Agent-Passport Mode A across $N = 1{,}200$ live socket and SQLite WAL transactions. Even at p_{99} (0.5240 ms; Mode B $p_{99} = 0.8120$ ms), Agent-Passport operates well below the 1.0 ms budget.

TABLE IV
PER-HOP GATEWAY VERIFICATION LATENCY (MEAN ± SD) & 4-HEADER WIRE FOOTPRINT ($k \in \{1, 2, 3, 4\}$ HOPS, $n_k = 300$ TRIALS/HOP)

Hop Depth ($n_k = 300$)	Wire Size A / B (B)	Passport Read S_1	Passport Mode A (ms)	Passport Mode B (ms)	Local IdP B2a (ms)	Net. IdP B2b (ms)	Mode A Speedup vs. B2a / B2b
$k = 1$ ($n = 300$)	1,180/1,372	0.2682 ± 0.017	0.2850 ± 0.018	0.3980 ± 0.027	0.2474 ± 0.019	10.4210 ± 0.57	$\mathbf{0.9\times}$ / $\mathbf{36.6\times}$
$k = 2$ ($n = 300$)	1,434/1,818	0.2727 ± 0.018	0.2896 ± 0.019	0.4664 ± 0.031	0.4948 ± 0.034	20.8380 ± 0.81	$\mathbf{1.7\times}$ / $\mathbf{72.0\times}$
$k = 3$ ($n = 300$)	1,688/2,264	0.2773 ± 0.018	0.2942 ± 0.019	0.5348 ± 0.035	0.7422 ± 0.046	31.2630 ± 0.99	$\mathbf{2.5\times}$ / $\mathbf{106.3\times}$
$k = 4$ ($n = 300$)	1,942/2,710	0.2818 ± 0.019	0.2988 ± 0.020	0.6032 ± 0.039	0.9896 ± 0.058	41.6780 ± 1.14	$\mathbf{3.3\times}$ / $\mathbf{139.5\times}$
All ($N = 1{,}200$)	**1,561/2,041**	$\mathbf{0.2750 \pm 0.018}$	$\mathbf{0.2919 \pm 0.019}$	$\mathbf{0.5006 \pm 0.034}$	$\mathbf{0.6185 \pm 0.042}$	$\mathbf{26.0500 \pm 1.14}$	$\mathbf{2.1\times}$ / $\mathbf{89.2\times}$

Note: Empirical socket means follow linear regression slopes of $+4.60$ μs/hop ($R^2 = 0.9998$) in Mode A and $+68.40$ μs/hop ($R^2 = 0.9999$) in Mode B.

1) Monotonic Sub-Millisecond Hop Scalability (3.3× vs. Local B2a; 139.5× vs. Networked B2b at 4 Hops): As shown in Fig. 2 and Table IV, even when the RFC 8693 IdP runs locally in-memory over `AF_UNIX` without PBKDF2 (B2a), performing k sequential IPC round-trips scales linearly from 0.2474 ms ($k = 1$) to 0.9896 ms ($k = 4$), while networked RFC 8693 (B2b) scales to 41.6780 ms at $k = 4$. In Agent-Passport Mode A, each additional hop adds $+4.6$ μs at $\mathcal{G}$ ($0.2850 \rightarrow 0.2988$ ms; cumulative path latency including k upstream holder attenuations at 4.2 μs/hop is $0.2892 \rightarrow 0.3156$ ms, while Mode B scales by $+68.4$ μs/hop at $\mathcal{G}$ from $0.3980 \rightarrow 0.6032$ ms and $0.4465 \rightarrow 0.7972$ ms including 48.5 μs/hop upstream Ed25519 keygen+sign). The total 4-header wire footprint grows by only $+254$ B/hop in Mode A ($1{,}180 \rightarrow 1{,}942$ B) and $+446$ B/hop in Mode B ($1{,}372 \rightarrow 2{,}710$ B), remaining well inside the default 8 KB HTTP/2 header frame limit. At $k = 4$, Mode A achieves a 3.3× speedup over B2a ($0.9896/0.2988$), a 139.5× speedup over B2b ($41.6780/0.2988$), and a 185.9× speedup over B3 ($55.5600/0.2988$). Table V reports live end-to-end tool-calling evaluations ($n = 20$ legitimate and $n = 20$ prompt-injected confused-deputy trials per model under Mode B Ed25519 + SQLite WAL at $k = 3$ hops) across `gemini-2.5-flash`, `gemini-2.5-pro`, and `gemini-3-flash-preview`, achieving 20/20 (100.0%, 95% Clopper-Pearson CI $[83.2\%, 100.0\%]$) escalation blocking with 0.0% benign false positives.

2) 100% Privilege Escalation, Loop Containment, HITL Draft Lock, & Buffer Zeroization: Across all 160 adversarial privilege escalation traces in S_5, Agent-Passport blocked 160/160 (100.0%, one-sided exact Fisher's $p = 4.65 \times 10^{-96}$ vs. B1 [0/160] and $p = 3.12 \times 10^{-37}$ vs. B4 [66/160]). Across all 160 cyclic traces in S_6, the sender-constrained `AS-PATH` verifier terminated 160/160 (100.0%) cycles in 0.2775 ms via error `-32097` (Fig. 3). In S_2 ($n = 240$), S_3 ($n = 200$), and S_4 ($n = 120$), Agent-Passport staged 240/240 (100.0%) drafts with `HTTP 202`, executed 200/200 (100.0%) co-signed mutations, and blocked 120/120 (100.0%) unsigned/replayed commits with `HTTP 428`, while verifying 100.0% post-turn buffer zeroization across all 520 executed turns and 100.0% deferred non-decryption across all 680 staged/rejected turns.

TABLE V
LIVE GOOGLE CLOUD VERTEX AI MULTI-MODEL EVALUATION (MODE B ED25519 + SQLITE WAL AT $k = 3$ HOPS, `location="global"`, $n = 20$ TRIALS/MODEL)

Official Vertex AI Model (`location="global"`)	LLM Synthesis Mean ± SD (ms)	3-Hop Mode B Verify (ms)	Legitimate Authorized	Escalation Blocked (−32098, 95% CI)
`gemini-2.5-flash`	$1{,}524.5 \pm 118.4$	0.510 ± 0.032	20/20 (**100%**)	20/20 (**100%**, [83.2%, 100%])
`gemini-2.5-pro`	$2{,}235.8 \pm 164.2$	0.528 ± 0.038	20/20 (**100%**)	20/20 (**100%**, [83.2%, 100%])
`gemini-3-flash-preview`	$1{,}763.4 \pm 131.6$	0.519 ± 0.035	20/20 (**100%**)	20/20 (**100%**, [83.2%, 100%])

VI. CONCLUSION

We presented **Agent-Passport**, a cryptographic wire protocol and gateway middleware that brings mathematical least-privilege attenuation, sender-constrained BGP-inspired loop prevention, wire-enforced human-in-the-loop draft locks, and deferred zero-copy buffer zeroization to multi-agent A2A and MCP swarms. Operating directly on HTTP/2 and JSON-RPC 2.0 transport headers in 291.9 μs (500.6 μs in Ed25519 Mode B), Agent-Passport eliminates centralized IdP bottlenecks while providing provable security and regulatory compliance for enterprise AI deployments.

REFERENCES

[1] G. Comanici *et al.* (Gemini Team, Google), "Gemini 2.5: Pushing the Frontier with Advanced Reasoning, Multimodality, Long Context, and Next Generation Agentic Capabilities," *arXiv preprint arXiv:2507.06261*, 2025.

[2] Google Cloud, "Agent2Agent (A2A) Protocol Specification," 2025. [Online]. Available: https://google.github.io/A2A/

[3] Anthropic, "Model Context Protocol Specification," Nov. 2024. [Online]. Available: https://spec.modelcontextprotocol.io/

[4] N. Tomašev, M. Franklin, and S. Osindero, "Intelligent AI Delegation," *arXiv preprint arXiv:2602.11865*, 2026.

[5] N. Hardy, "The Confused Deputy: (or why capabilities might have been invented)," *ACM SIGOPS Operating Systems Review*, vol. 22, no. 4, pp. 36–38, 1988.

[6] B. Campbell, C. Mortimore, and M. B. Jones, "Security Assertion Markup Language (SAML) 2.0 Profile for OAuth 2.0 Client Authentication and Authorization Grants," *IETF RFC 7522*, May 2015.

[7] R. Tsao and X. Xin, "3 new ways to authorize users to your private workloads on Cloud Run," *Google Cloud Blog & Cloud Run Authenticating Service-to-Service Documentation*, 2023.

[8] M. Jones and D. Hardt, "The OAuth 2.0 Authorization Framework: Bearer Token Usage," *IETF RFC 6750*, Oct. 2012.

[9] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," in *Proc. ACM Workshop on Artificial Intelligence and Security (AISec)*, 2023, pp. 79–90.

[10] Q. Zhan, Z. Liang, Z. Ying, and D. D. Kang, "InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents," in *Findings of the Association for Computational Linguistics: ACL 2024*, 2024, pp. 10471–10506.

[11] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents," in *Advances in Neural Information Processing Systems (NeurIPS)*, 2024, pp. 82895–82920.

[12] M. Jones, A. Nadalin, B. Campbell, J. Bradley, and C. Mortimore, "OAuth 2.0 Token Exchange," *IETF RFC 8693*, Jan. 2020.

[13] A. Raut, "Transaction Tokens for Agents," *IETF Internet-Draft draft-araut-oauth-transaction-tokens-for-agents-01*, 2026.

[14] A. Prasad, R. Krishnan, D. Lopez, and S. Addepalli, "Cryptographically Verifiable Actor Chains for OAuth 2.0 Token Exchange," *IETF Internet-Draft draft-mw-spice-actor-chain-00*, 2026.

[15] J. Chow, B. Pfaff, T. Garfinkel, and M. Rosenblum, "Shredding Your Garbage: Reducing Data Lifetime Through Secure Deallocation," in *Proc. 14th USENIX Security Symp.*, 2005, pp. 331–346.

[16] Z. Yang, B. Johannesmeyer, A. T. Olesen, S. Lerner, and K. Levchenko, "Dead Store Elimination (Still) Considered Harmful," in *Proc. 26th USENIX Security Symp.*, 2017, pp. 1025–1040.

[17] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," *NIST Special Publication 800-207*, Aug. 2020.

[18] Y. Rekhter, T. Li, and S. Hares, "A Border Gateway Protocol 4 (BGP-4)," *IETF RFC 4271*, Jan. 2006.

[19] European Parliament and Council of the European Union, "Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)," *Official Journal of the European Union*, 2024.

[20] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrable, and M. Lentczner, "Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud," in *Proc. Network and Distributed System Security Symp. (NDSS)*, 2014.

[21] S. Prakash, "AIP: Agent Identity Protocol for Verifiable Delegation Across MCP and A2A," *arXiv preprint arXiv:2603.24775*, 2026.

[22] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr, "Defeating Prompt Injections by Design," in *Proc. IEEE Conf. Secure and Trustworthy Machine Learning (SaTML)*, 2026, pp. 587–618 (arXiv:2503.18813).

[23] M. F. M. Costa, B. Köpf, A. Kolluri, A. Paverd, M. Russinovich, A. Salem, S. Tople, L. Wutschitz, and S. Zanella-Béguelin, "Securing AI Agents with Information-Flow Control," *arXiv preprint arXiv:2505.23643*, 2025.

[24] T. Shi *et al.*, "Progent: Programmable Privilege Control for LLM Agents," *arXiv preprint arXiv:2504.11703*, 2025.

[25] N. Maloyan and D. Namiot, "Breaking the Protocol: Security Analysis of the Model Context Protocol Specification and Prompt Injection Vulnerabilities in Tool-Integrated LLM Agents," *arXiv preprint arXiv:2601.17549*, 2026.

[26] H. Zhang, J. Huang, K. Mei, Y. Yao, Z. Wang, C. Zhan, H. Wang, and Y. Zhang, "Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents," in *Proc. Int. Conf. Learning Representations (ICLR)*, 2025.

[27] D. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones, and D. Waite, "OAuth 2.0 Demonstrating Proof-of-Possession (DPoP)," *IETF RFC 9449*, Sept. 2023.

[28] B. Campbell, J. Bradley, N. Sakimura, and T. Lodderstedt, "OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens," *IETF RFC 8705*, Feb. 2020.

[29] T. Lodderstedt, J. Richer, and B. Campbell, "OAuth 2.0 Rich Authorization Requests," *IETF RFC 9396*, May 2023.

[30] J. A. Salowey, Y. Rosomakho, and H. Tschofenig, "Workload Identity in Multi System Environments (WIMSE) Architecture," *IETF Internet-Draft draft-ietf-wimse-arch-07*, 2026.

[31] N. A. Niyikiza, "Attenuating Authorization Tokens for Agentic Delegation Chains," *IETF Internet-Draft draft-niyikiza-oauth-attenuating-agent-tokens-00*, Feb. 2026.

[32] H. Birkholz, D. Thaler, M. Richardson, N. Smith, and W. Pan, "Remote ATtestation procedureS (RATS) Architecture," *IETF RFC 9334*, Jan. 2023.